



COMPETENCY STANDARD

FOR

CYBER SECURITY (ADVANCED)

Skills for Industry Competitiveness and Innovation Program (SICIP)
Finance Division, Ministry of Finance

COPYRIGHT

The Competency Standards for Cyber Security is a document for developing curricula, teaching and learning materials, and assessment tools. It also serves as the document for providing training consistent with the requirements of the industry for individuals who pass through the set standard via assessment. Subsequently, they would be qualified and settled for a relevant job.

This document has been developed to use in training under the **Skills for Industry Competitiveness and Innovation Program (SICIP)** to meet the skills requirements of the Information and Communication Technology (ICT) sector. This document is owned by the Finance Division of the Ministry of Finance of the People's Republic of Bangladesh.

Public and private institutes may use the information contained in this competency standard for training activities benefitting Bangladesh.

Other interested parties must obtain permission from the owner of this document for reproduction of information in any manner in whole or in part of this Skills Standard, in English or other languages.

This document is available at:

Skills for Industry Competitiveness and Innovation Program (SICIP)
Finance Division, Ministry of Finance,
Probashi Kallyan Bhaban (Level-15 & 16)
71-72 Eskaton Garden, Dhaka-1000
Phone: +8802 55138753-55, Fax: +88 02 55138752
Website: <https://sicip.gov.bd/>

INTRODUCTION:

The Skills for Industry Competitiveness and Innovation Program (SICIP) has the overall objective of developing a skilled workforce adept at handling new technologies, especially for emerging industries in Bangladesh. It will expand skills training and strengthen the development of the training ecosystem to address the skills requirements of the SICIP-selected industry sectors. The program aims to (i) increase the technology-oriented skilled workforce across emerging and priority sectors, (ii) promote inclusive skilling and upskilling opportunities for women and socially disadvantaged groups, (iii) incentivize industry-university partnerships to nurture innovation capacity and improve industry competitiveness, and (iv) foster skills for climate-resilient manufacturing processes and green technologies. The program is expected to benefit about 220,000 new and existing workers over a 6-year implementation period from 2024-2029.

The SICIP Program has, therefore, taken the initiative to enhance the employability and productivity of trainees by implementing market-responsive and job-focused training programs through public and private training providers. This will require the development of competency standards for each of the occupations/trades which will provide a structured framework in the learning process to guide training providers, ensure consistent training quality, and create an alignment between the skills provided by the training institutes and the needs of the industry.

This competency standard is therefore developed to improve skills following the job roles and skill sets of the occupation and ensure that the required skills are aligned with industry requirements.

The Competency Standard also suggests integration of YouTube or similar digital platforms or downloaded clips into classroom practice to ensure simulated creation of the contents so that learners are exposed to visual demonstrations before classroom instruction or practical session, which aligns with modern learning preference and supports flipped classroom models.

The document details the format, sequencing, wording, and layout of the Competency Standard for an occupation which comprises Units of Competence and its corresponding Elements.

OVERVIEW:

A **Competency Standard** is a written specification of the knowledge, skills, and attitudes required for the performance of a job or occupation or trade corresponding to the standard of performance required in the workplace.

Competency standard:

- provides a consistent and reliable set of components for training, recognizing, and assessing people's skills, and may also have optional support materials.
- enables industry-recognized qualifications to be awarded through direct assessment of workplace competencies
- encourages the development and delivery of flexible training that suits individual and industry requirements
- encourages learning and assessment in a work-related environment, which leads to verifiable workplace outcomes.

Competency Standard has been developed by a working group comprised of occupation-specific experts from the industry/institution and relevant consultants of SICIP.

Competency Standards describe the skills, knowledge, and attitude needed to perform effectively in the workplace. Competency Standards acknowledge that people can achieve vocational and technical competency in many ways by emphasizing what the learner can do, not how or where they learned to do it.

With Competency Standards, assessment and training may be conducted at the workplace, at training organization, during regular work, or through work experience, work placement, work simulation or any combination of these.

A Unit of Competency describes a distinct work activity that would normally be undertaken by one person in accordance with industry standards.

Units of Competency are documented in a standard format that comprises:

- Reference to Industry Sector, Occupational Title and Occupational Description
- Unit code
- Unit title
- Unit descriptor
- Elements and performance criteria
- Variables and range statement
- Evidence guides

Together all the parts of a Unit of Competency:

- Describe a work activity
- Guide the assessor in determining whether the candidate is competent.

The ensuing sections of this document comprise a description of the respective occupation with all the key components of a Unit of Competence:

- An overview of all Units of Competence for the occupation and their corresponding duration required for completion of training.

- The Competency Standards that include the Unit of Competency, Unit Descriptor, Elements and Performance Criteria, Range of Variables, Curricular Content Guide, and Assessment Evidence Guide.

Occupation Specific Competency (120 Hrs.)

Code	Unit of Competency	Elements of Competency	Duration (hours)
SICIP-ICT-CS-01-O	Apply Software Security Fundamentals	1. Interpret concepts software and cybersecurity 2. Identify cyber threats, and software vulnerabilities 3. Interpret secure software development practices, 4. Perform basic security risk assessment 5. Comply with security policies and ethics	15
SICIP-ICT-CS-02-O	Apply Secure Coding Practices	1. Set up a secure development environment 2. Validate user inputs and outputs 3. Implement authentication and authorization 4. Protect sensitive data using cryptography 5. Implement secure error handling and logging 6. Integrate secure APIs and libraries	30
SICIP-ICT-CS-03-O	Secure Web Applications and Databases	1. Configure web application and server security 2. Mitigate common web attacks 3. Implement session and access control 4. Secure database and connectivity 5. Monitor security events and alerts	25
SICIP-ICT-CS-04-O	Perform Vulnerability Assessment and	1. Prepare testing environment 2. Perform static application	25

Code	Unit of Competency	Elements of Competency	Duration (hours)
	Security Testing	security testing (SAST) 3. Perform dynamic application security testing (DAST) 4. Analyze vulnerability findings 5. Verify security controls 6. Prepare vulnerability assessment reports	
SICIP-ICT-CS-05-O	Develop a Secure Software Project (Capstone)	1. Plan the project requirements 2. Design the secure application 3. Develop the application 4. Perform security testing and remediate 5. Prepare project documentation 6. Present project outcomes	25
Total:			0 Hrs.

Occupation Specific Competencies

Unit of Competency: APPLY SOFTWARE SECURITY FUNDAMENTALS	Nominal Duration: 15 Hrs.	Unit Code: SICIP-ICT-CS-01-O
Unit Descriptor: This unit covers the knowledge, skills and attitudes required to apply software security fundamentals. It specifically includes the tasks of Interpreting concepts software and cybersecurity, Identifying cyber threats, and software vulnerabilities, Interpreting secure software development practices, performing basic security risk assessment and complying with security policies and ethics.		

Elements and Performance Criteria:

(Terms in the performance criteria that are written in **bold and underlined** are elaborated in the range of variables).

Elements of Competency	Performance Criteria
1. Interpret concepts software and cybersecurity	1.1 Basic <u>cybersecurity concepts</u> are interpreted according to industry-accepted definitions. 1.2 The <u>security principles</u> of confidentiality, integrity and availability are explained in the context of software applications. 1.3 The distinction between cybersecurity and software security is described according to standard references. 1.4 Common <u>security terminologies</u> are identified and used correctly. 1.5 The importance of security in the software development process is explained according to industry requirements.
2. Identify cyber threats, and software vulnerabilities	2.1 Common <u>cyber threats and attacks</u> are identified according to industry references. 2.2 Common <u>software vulnerabilities</u> including the OWASP Top 10 are identified and classified. 2.3 Threat sources and attack vectors are analyzed according to their impact on software applications. 2.4 The relationship between vulnerabilities, threats and risks is explained according to standard references. 2.5 Findings are documented following organizational reporting procedures.
3. Interpret secure software development practices	3.1 The phases of the <u>secure software development lifecycle (SSDLC)</u> are interpreted according to industry practice. 3.2 Security activities are mapped to each SSDLC phase according to standard guidelines.

	3.3 Relevant <u>security standards and guidelines</u> are interpreted according to applicable references. 3.4 The role of security controls within the SSDLC is explained according to industry requirements. 3.5 The benefits of integrating security throughout the development lifecycle are described according to standard references.
4. Perform basic security risk assessment	4.1 A <u>threat modeling method</u> is selected according to the application context. 4.2 Assets, entry points and trust boundaries are identified according to standard procedures. 4.3 Threats are enumerated and categorized using a recognized threat model. 4.4 Security <u>risks</u> are assessed and rated according to likelihood and impact. 4.5 Appropriate mitigation measures are recommended according to the assessed risk level. 4.6 Threat modeling and risk assessment results are documented following organizational procedures.
5. Comply with security policies and ethics	5.1 Applicable <u>cyber laws and regulations</u> are interpreted according to jurisdictional requirements. 5.2 <u>Professional ethics</u> are applied in performing security-related activities. 5.3 Organizational <u>security policies</u> are complied with during software development activities. 5.4 Data protection and privacy requirements are observed according to applicable regulations. 5.5 Non-compliance issues are reported following organizational procedures.

Range of Variables

Variable	Range (May includes but not limited to):
1. Cybersecurity concepts	1.1 Confidentiality Integrity Availability (CIA triad) 1.2 Authentication Authorization 1.3 Accountability 1.4 Non-repudiation Defense in depth 1.5 Least privilege Attack surface 1.6 Security controls
2. Security principles	2.1 Confidentiality Integrity 2.2 Availability Least privilege 2.3 Separation of duties 2.4 Fail-safe defaults 2.5 Defense in depth

	2.6 Economy of mechanism 2.7 Complete mediation Secure by design
3. Security terminologies	3.1 Threat Vulnerability 3.2 Risk Exploit 3.3 Payload 3.4 Attack vector 3.5 Threat actor 3.6 Asset Zero-day 3.7 Patch Malware 3.8 Phishing
4. Cyber threats and attacks	4.1 Malware (virus, worm, trojan, ransomware, spyware) 4.2 Phishing and social engineering 4.3 Denial of Service (DoS/DDoS) 4.4 Man-in-the-middle attacks 4.5 Brute force attacks 4.6 Password attacks Insider threats 4.7 Advanced Persistent Threats (APT) 4.8 Supply chain attacks
5. Software vulnerabilities	5.1 Broken access control 5.2 Cryptographic failures Injection Insecure design 5.3 Security misconfiguration 5.4 Vulnerable and outdated components Identification and authentication failures 5.5 Software and data integrity failures 5.6 Security logging and monitoring failures 5.7 Server-side request forgery (OWASP Top 10) 5.8 Buffer overflow Race conditions
6. Secure software development lifecycle (SSDLC)	6.1 Requirements and security requirements 6.2 Secure design and threat modeling 6.3 Secure coding and implementation 6.4 Security testing and code review 6.5 Secure deployment Operations 6.6 Maintenance and patch management
7. Security standards and guidelines	7.1 OWASP (Top 10, ASVS, SAMM) 7.2 ISO/IEC 27001 7.3 NIST (Cybersecurity Framework, SSDF, SP 800-53) 7.4 CIS Controls 7.5 PCI DSS GDPR principles Bangladesh 7.6 Digital Security Act
8. Threat modeling method	8.1 STRIDE 8.2 DREAD 8.3 PASTA 8.4 Attack trees 8.5 Data flow diagram-based modeling

9. Risks	9.1 Likelihood Impact Risk rating (low, medium, high, critical) 9.2 Inherent risk Residual risk 9.3 Risk register 9.4 Risk acceptance 9.5 Risk mitigation 9.6 Risk transfer 9.7 Risk avoidance
10. Cyber laws and regulations	10.1 Digital Security Act of Bangladesh ICT Act 10.2 Data protection regulations Intellectual property laws 10.3 Computer misuse provisions international conventions
11. Professional ethics	11.1 Confidentiality of client information 11.2 Responsible disclosure Integrity and honesty 11.3 Avoidance of conflict of interest 11.4 Compliance with codes of conduct 11.5 Respect for privacy 11.6 Lawful use of tools and techniques
12. Security policies	12.1 Acceptable use policy 12.2 Access control policy 12.3 Password policy 12.4 Data classification policy Incident response policy 12.5 Change management policy 12.6 Bring Your Own Device (BYOD) policy

Curricular Content Guide

1. Underpinning Knowledge	1.1 Concepts of cybersecurity and software security. 1.2 Understand the CIA triad and core security principles. 1.3 Identify common cyber threats, attacks, and software vulnerabilities including the OWASP Top 10. 1.4 Understand the phases of the secure software development lifecycle (SSDLC). 1.5 Identify relevant security standards and guidelines (OWASP, ISO/IEC 27001, NIST). 1.6 Understand threat modeling methods and security risk assessment procedures. 1.7 Understand applicable cyber laws, professional ethics, and organizational security policies. 1.8 Identify data protection and privacy requirements.
2. Underpinning Skills	2.1 Applying core security concepts and principles to software contexts. 2.2 Identifying and classifying cyber threats, attacks, and software vulnerabilities. 2.3 Mapping security activities to the phases of the SSDLC. 2.4 Interpreting and applying security standards and guidelines.

	2.5 Performing basic threat modeling using a recognized method. 2.6 Assessing and rating security risks by likelihood and impact. 2.7 Documenting threat modeling and risk assessment results. 2.8 Complying with cyber laws, professional ethics, and organizational security policies.
3. Underpinning Attitudes	3.1 Commitment to occupational health and safety 3.2 Promptness in carrying out activities 3.3 Sincerity and honesty to duties 3.4 Environmental concerns 3.5 Eagerness to learn 3.6 Tidiness and timeliness 3.7 Respect for rights of peers and seniors in the workplace 3.8 Good relationships with peers, sub-ordinates and seniors in the workplace
4. Resource Implications	The following resources must be provided: 4.1 Workplace (simulated or actual). 4.2 Relevant tools, equipment, software, and facilities needed to perform the activities. 4.3 Required learning materials. Specifications and work instructions.

Assessment Evidence Guide

1. Critical Aspects of Competency	Assessment required evidence that the candidate: 1.1 interpreted concepts software and cybersecurity 1.2 identified cyber threats, and software vulnerabilities 1.3 interpreted secure software development practices, 1.4 performed basic security risk assessment 1.5 complied with security policies and ethics
2 Methods of Assessment	Competency should be assessed by: 2.1 Written test 2.2 Practical Demonstration 2.3 Oral Questioning 2.4 Portfolio (Optional)
3 Context of Assessment	3.1 Competency assessment must be done in an assessment/training center or in an actual or simulated work place after completion of the training. 3.2 Assessment should be done by a nationally certified assessor or occupation-specific industry expert.

Unit of Competency:	Nominal	Unit Code:
----------------------------	----------------	-------------------

APPLY SECURE CODING PRACTICES	Duration: 30 Hrs.	SICIP-ICT-CS-02-O
Unit Descriptor: This unit covers the knowledge, skills and attitudes required to It specifically apply secure coding practices. It includes the tasks of setting up a secure development environment, validating user inputs and outputs, implementing authentication and authorization, protecting sensitive data using cryptography, implementing secure error handling and logging, & integrating secure APIs and libraries.		

Elements and Performance Criteria:

(Terms in the performance criteria that are written in **bold and underlined** are elaborated in the range of variables).

Elements of Competency	Performance Criteria
1. Set up a secure development environment	1.1 Development <u>tools and platforms</u> are selected and installed according to project requirements. 1.2 Secure <u>configuration settings</u> are applied to the development environment according to standard guidelines. 1.3 A version control system is set up and access is controlled according to organizational procedures. 1.4 Dependencies and development tools are kept updated and patched according to standard practice. 1.5 The development environment is maintained and monitored following secure configuration requirements.
2. Validate user inputs and outputs	2.1 Trusted and untrusted <u>input sources</u> are identified according to the application design. 2.2 <u>Input validation techniques</u> are applied to validate all inputs according to secure coding standards. 2.3 <u>Output encoding techniques</u> are applied to prevent injection according to the output context. 2.4 Data sanitization is performed for all external data according to secure coding standards. 2.5 Validation and encoding controls are tested to confirm the intended behavior.
3. Implement authentication and authorization	3.1 <u>Authentication mechanisms</u> are implemented according to security requirements. 3.2 Credentials are stored securely using approved <u>credential protection methods</u> . 3.3 <u>Authorization models</u> are implemented to enforce least privilege access. 3.4 Session identifiers are generated and managed according to secure coding standards. 3.5 Authentication and authorization controls are tested to

	confirm correct enforcement.
4. Protect sensitive data using cryptography	4.1 <u>Sensitive data</u> requiring protection is identified according to data classification requirements. 4.2 Appropriate <u>cryptographic algorithms</u> are selected according to industry standards. 4.3 Data at rest is encrypted using approved algorithms and key lengths. 4.4 Data in transit is protected using <u>secure protocols</u>. 4.5 Cryptographic keys are generated, stored and managed following <u>key management practices</u>.
5. Implement secure error handling and logging	5.1 <u>Errors and exceptions</u> are handled securely without exposing sensitive information. 5.2 Generic error messages are presented to users according to secure coding standards. 5.3 Security-relevant <u>logging events</u> are logged according to organizational requirements. 5.4 Logs are protected from unauthorized access and tampering according to standard practice. 5.5 Error handling and logging controls are tested to confirm the intended behavior.
6. Integrate secure APIs and libraries	6.1 Third-party <u>libraries and components</u> are selected from trusted sources according to organizational policy. 6.2 Components are checked for known vulnerabilities using <u>dependency scanning tools</u>. 6.3 APIs are integrated securely using authenticated and authorized access according to secure coding standards. 6.4 API keys and secrets are stored and managed securely according to standard practice. 6.5 Integrated libraries and APIs are updated and patched following configuration management procedures.

Range of Variables

Variable	Range (May includes but not limited to):
1. Tools and platforms	1.1 Integrated Development Environment (IDE) 1.2 Compilers and interpreters 1.3 Version control system (Git) 1.4 Package and dependency managers 1.5 Containerization tools 1.6 Build automation tools Static analysis plugins 1.7 Virtual machines
2. Configuration settings	2.1 Secure default configurations 2.2 Least privilege access

	2.3 Disabled unused services and features 2.4 Hardened compiler flags 2.5 Secrets management configuration 2.6 Repository access controls 2.7 Environment separation (development, testing, production)
3. Input sources	3.1 Form fields URL parameters 3.2 HTTP headers Cookies 3.3 File uploads API request bodies 3.4 Query strings 3.5 Command-line arguments 3.6 Database inputs Third-party data feeds
4. Input validation techniques	4.1 Allow-list (whitelist) validation 4.2 Data type validation 4.3 Length and range checking 4.4 Format and pattern (regex) validation 4.5 Canonicalization 4.6 Server-side validation 4.7 Boundary checking
5. Output encoding techniques	5.1 HTML encoding 5.2 URL encoding 5.3 JavaScript encoding 5.4 CSS encoding 5.5 Attribute encoding 5.6 Parameterized queries / prepared statements 5.7 Context-aware encoding
6. Authentication mechanisms	6.1 Username and password 6.2 Multi-factor authentication (MFA) 6.3 Token-based authentication (JWT, OAuth 2.0) 6.4 Single Sign-On (SSO) 6.5 Certificate-based authentication 6.6 Biometric authentication 6.7 Password policies and account logout
7. Credential protection methods	7.1 Salted password hashing (bcrypt, Argon2, PBKDF2) 7.2 Secure credential vaults 7.3 Environment variables 7.4 Secrets management systems 7.5 Avoidance of hard-coded credentials
8. Authorization models	8.1 Role-Based Access Control (RBAC) 8.2 Attribute-Based Access Control (ABAC) 8.3 Discretionary Access Control (DAC) 8.4 Mandatory Access Control (MAC) 8.5 Principle of least privilege 8.6 Access control lists

9. Sensitive data	9.1 Personally Identifiable Information (PII) 9.2 Authentication credentials 9.3 Financial and payment data Health records 9.4 Session tokens 9.5 Cryptographic keys Intellectual property 9.6 Business confidential data
10. Cryptographic algorithms	10.1 AES (symmetric encryption) RSA and ECC (asymmetric encryption) 10.2 SHA-256/SHA-3 (hashing) 10.3 HMAC (message authentication) 10.4 TLS cipher suites Argon2/bcrypt (password hashing) 10.5 Approved key lengths
11. Secure protocols	11.1 TLS/SSL 11.2 HTTPS 11.3 SSH 11.4 SFTP/FTPS 11.5 IPsec 11.6 VPN
12. Key management practices	12.1 Secure key generation 12.2 Secure key storage 12.3 Key rotation 12.4 Key distribution 12.5 Key revocation 12.6 Hardware security modules (HSM) 12.7 Key lifecycle management
13. Errors and exceptions	13.1 Runtime exceptions Input errors 13.2 System errors 13.3 Application errors 13.4 Boundary errors 13.5 Fail-secure handling 13.6 Try-catch blocks
14. Logging events	14.1 Authentication attempts 14.2 Access control decisions Input validation failures 14.3 Application errors and exceptions 14.4 Administrative actions 14.5 Data access events 14.6 Security configuration changes
15. Libraries and components	15.1 Open-source libraries 15.2 Commercial libraries 15.3 Frameworks Software 15.4 Development Kits (SDK) 15.5 Plugins and modules 15.6 Container images 15.7 Runtime dependencies

16. Dependency scanning tools	16.1 Software Composition Analysis (SCA) tools 16.2 OWASP 16.3 Dependency-Check Snyk npm audit / pip audit 16.4 Vulnerability databases (CVE, NVD) 16.5 Software Bill of Materials (SBOM)
-------------------------------	---

Curricular Content Guide

1. Underpinning Knowledge	1.1 Concepts of secure coding and defensive programming. 1.2 Identify secure development tools, platforms, and configuration settings. 1.3 Understand input validation and output encoding techniques. 1.4 Understand authentication and authorization mechanisms. 1.5 Understand cryptographic techniques for protecting data at rest and in transit. 1.6 Understand key management practices. 1.7 Understand secure error/exception handling and security logging. 1.8 Understand secure integration of third-party libraries and APIs. 1.9 Identify secure coding standards and workplace requirements.
2. Underpinning Skills	2.1 Setting up and maintaining a secure development environment. 2.2 Applying input validation and output encoding techniques to prevent injection. 2.3 Implementing authentication and authorization mechanisms enforcing least privilege. 2.4 Applying cryptographic techniques to protect sensitive data at rest and in transit. 2.5 Managing cryptographic keys according to key management practices. 2.6 Implementing secure error/exception handling and security logging. 2.7 Integrating third-party libraries and APIs securely. 2.8 Testing security controls to confirm the intended behaviour.
3. Underpinning Attitudes	3.1 Commitment to occupational health and safety 3.2 Promptness in carrying out activities 3.3 Sincere and honest to duties 3.4 Environmental concerns 3.5 Eagerness to learn 3.6 Tidiness and timeliness 3.7 Respect for rights of peers and seniors in the workplace 3.8 Communication with peers, subordinates and seniors in

	the workplace
4. Resource Implications	The following resources must be provided: 4.1 Workplace (simulated or actual) 4.2 Relevant tools, equipment, software, and facilities needed to perform the activities. 4.3 Required learning materials. 4.4 Specifications and work instructions.

Assessment Evidence Guide

1. Critical Aspects of Competency	Assessment required evidence that the candidate: 1.1 set up a secure development environment 1.2 validated user inputs and outputs 1.3 implemented authentication and authorization 1.4 protected sensitive data using cryptography 1.5 implemented secure error handling and logging 1.6 integrated secure APIs and libraries
2. Methods of Assessment	Competency should be assessed by: 2.1 Written test 2.2 Practical Demonstration 2.3 Oral Questioning 2.4 Portfolio (Optional)
3. Context of Assessment	3.1 Competency assessment must be done in an assessment/training center or in an actual or simulated work place after completion of the training. 3.2 Assessment should be done by a nationally certified assessor or occupation-specific industry expert.

Unit of Competency: SECURE WEB APPLICATIONS AND DATABASES	Nominal Duration: 25 Hrs.	Unit Code: SICIP-ICT-CS-03-O
Unit Descriptor: This unit covers the knowledge, skills and attitudes required to secure web applications and databases. It specifically includes the tasks of configuring web application and server security, mitigating common web attacks, implementing session and access control, securing database and connectivity and monitoring security events and alerts.		

Elements and Performance Criteria:

(Terms in the performance criteria that are written in **bold and underlined** are elaborated in the range of variables).

Elements of Competency	Performance Criteria
1. Configure web application and server security	1.1 Web <u>server and application settings</u> are configured according to secure configuration guidelines. 1.2 <u>HTTPS/TLS</u> is configured to secure communication according to industry standards. 1.3 Security <u>HTTP headers</u> are configured to protect the application. 1.4 Content Security Policy (CSP) is configured to restrict content sources according to application requirements. 1.5 Server hardening measures are applied and verified according to standard practice.
2. Mitigate common web attacks	2.1 Common <u>web attacks</u> are identified according to industry references. 2.2 SQL injection is prevented using parameterized queries and input validation. 2.3 Cross-site scripting (XSS) is prevented using output encoding and content security controls. 2.4 Cross-site request forgery (CSRF) is prevented using anti-CSRF tokens according to secure coding standards. 2.5 <u>File upload attacks</u> are mitigated according to secure coding standards. 2.6 Mitigation controls are tested to confirm their effectiveness.
3. Implement session and access control	3.1 <u>Session identifiers</u> are generated, transmitted and stored securely according to secure coding standards. 3.2 Session timeout and invalidation are configured according to security requirements. 3.3 <u>Access control mechanisms</u> are implemented to enforce least privilege. 3.4 Direct object references are protected against

	unauthorized access according to secure coding standards. 3.5 Session management and access control are tested to confirm correct enforcement.
4. Secure database and connectivity	4.1 Database hardening measures are applied according to secure configuration guidelines. 4.2 Database user privileges are assigned according to the principle of least privilege. 4.3 Database connectivity is secured using encrypted connections and secure credentials. 4.4 Sensitive data is protected using encryption and masking according to data classification requirements. 4.5 Database backups are configured and secured according to organizational procedures.
5. Monitor security events and alerts	5.1 Application security monitoring tools are configured according to organizational requirements. 5.2 Security events and alerts are monitored and analyzed according to standard procedures. 5.3 Suspicious activities are identified and escalated following the incident response procedure. 5.4 Response actions are performed to contain and mitigate incidents according to organizational procedures. 5.5 Security events and response actions are documented following organizational procedures.

Range of Variables

Variable	Range (May includes but not limited to):
1. Server and application settings	1.1 Directory and file permissions 1.2 Disabled default accounts and services 1.3 Error message configuration 1.4 Removal of default and sample content 1.5 Secure cookie attributes 1.6 Timeout settings 1.7 Logging configuration 1.8 Patch and update management
2. HTTPS/TLS	2.1 TLS certificate installation 2.2 Strong cipher suites 2.3 TLS version enforcement (TLS 1.2/1.3) 2.4 HTTP Strict 2.5 Transport Security (HSTS) 2.6 Certificate validity and renewal 2.7 Perfect forward secrecy 2.8 Redirect HTTP to HTTPS

3. HTTP headers	3.1 Content-Security-Policy (CSP) 3.2 X-Content-Type-Options 3.3 X-Frame-Options 3.4 Strict-Transport-Security (HSTS) 3.5 Referrer-Policy 3.6 Permissions-Policy 3.7 Cache-Control 3.8 X-XSS-Protection
4. Web attacks	4.1 SQL injection 4.2 Cross-site scripting (XSS) 4.3 Cross-site request forgery (CSRF) 4.4 File upload attacks 4.5 Command injection 4.6 Directory traversal 4.7 Broken authentication 4.8 Insecure direct object references 4.9 Server-side request forgery (SSRF) 4.10 Clickjacking
5. File upload attacks	5.1 Malicious file execution 5.2 Unrestricted file type upload 5.3 Oversized file upload 5.4 Path traversal via filenames 5.5 Content-type validation 5.6 File size limits 5.7 Storage outside web root 5.8 Anti-malware scanning
6. Session identifiers	6.1 Session tokens 6.2 Session cookies 6.3 Token entropy and randomness 6.4 Secure and HttpOnly cookie flags 6.5 SameSite attribute 6.6 Token binding 6.7 Regeneration after authentication
7. Access control mechanisms	7.1 Role-Based Access Control (RBAC) 7.2 Attribute-Based Access Control (ABAC) 7.3 Access control lists 7.4 Function-level access control 7.5 Object-level access control 7.6 Least privilege enforcement 7.7 Deny-by-default policy
8. Hardening measures	8.1 Removing default accounts and databases 8.2 Disabling unused features and stored procedures 8.3 Applying security patches 8.4 Restricting network access

	8.5 Enabling auditing 8.6 Configuring strong authentication 8.7 Limiting privileges
9. Connectivity	9.1 Encrypted connections (TLS) 9.2 Secure connection strings 9.3 Parameterized database access 9.4 Connection pooling with least privilege accounts 9.5 Firewall and network segmentation 9.6 Secure credential storage 9.7 Restricted remote access
10. Monitoring tools	10.1 Security Information and Event Management (SIEM) 10.2 Web Application Firewall (WAF) 10.3 Intrusion Detection/Prevention Systems (IDS/IPS) 10.4 Log management tools 10.5 Application performance monitoring 10.6 Alerting and dashboards
11. Events and alerts	11.1 Authentication failures 11.2 Access control violations 11.3 Injection attempts 11.4 Anomalous traffic patterns 11.5 Privilege escalation attempts 11.6 Configuration changes 11.7 Malware detections 11.8 System and application errors

Curricular Content Guide

1. Underpinning Knowledge	1.1 Concepts of web application and database security. 1.2 Identify web server, application, and database configuration settings. 1.3 Understand HTTPS/TLS, security headers, and Content Security Policy. 1.4 Understand common web attacks and their mitigation techniques. 1.5 Understand secure session management and access control. 1.6 Understand database hardening and secure database connectivity. 1.7 Understand application security monitoring and incident response. 1.8 Identify secure configuration guidelines and workplace requirements.
2. Underpinning Skills	2.1 Configuring web application and server security including HTTPS/TLS, security headers, and CSP. Mitigating common web attacks.

	2.2 Implementing secure session management and access control. 2.3 Hardening database systems and securing database connectivity. 2.4 Protecting sensitive data using encryption and masking. 2.5 Configuring monitoring tools and analyzing security events and alerts. 2.6 Responding to and documenting security incidents according to organizational procedures.
3. Underpinning Attitudes	3.1 Commitment to occupational health and safety. 3.2 Promptness in carrying out activities. 3.3 Sincere and honest to duties. 3.4 Environmental concerns. 3.5 Eagerness to learn. 3.6 Tidiness and timeliness. 3.7 Respect for rights of peers and seniors in the workplace. 3.8 Communication with peers, subordinates and seniors in the workplace.
4. Resource Implications	The following resources must be provided: 4.1 Workplace (simulated or actual) 4.2 Relevant tools, equipment, software, and facilities needed to perform the activities. 4.3 Required learning materials. 4.4 Specifications and work instructions

Assessment Evidence Guide

1. Critical Aspects of Competency	Assessment required evidence that the candidate: 1.1 configured web application and server security 1.2 mitigated common web attacks 1.3 implemented session and access control 1.4 secured database and connectivity 1.5 monitored security events and alerts		
2. Methods of Assessment	Competency should be assessed by: 2.1 Written test 2.2 Practical Demonstration 2.3 Oral Questioning 2.4 Portfolio (Optional)		
3. Context of Assessment	3.1 Competency assessment must be done in an assessment/training center or in an actual or simulated work place after completion of the training. 3.2 Assessment should be done by a nationally certified assessor or occupation-specific industry expert.		
Unit of Competency:		Nominal Duration:	Unit Code:

PERFORM VULNERABILITY ASSESSMENT AND SECURITY TESTING	25 Hrs.	SICIP-ICT-CS-04-O
Unit Descriptor: This unit covers the knowledge, skills and attitudes required to perform vulnerability assessment and security testing. It specifically includes the tasks of preparing testing environment, performing static application security testing (SAST), performing dynamic application security testing (DAST), analyzing vulnerability findings, verifying security controls and preparing vulnerability assessment reports.		

Elements and Performance Criteria:

(Terms in the performance criteria that are written in **bold and underlined** are elaborated in the range of variables).

Elements of Competency	Performance Criteria
1. Prepare testing environment	1.1 The assessment <u>scope and objectives</u> are defined according to organizational requirements. 1.2 A vulnerability assessment plan is prepared according to standard methodology. 1.3 Testing <u>tools</u> are selected and configured according to the assessment scope. 1.4 A test environment is set up according to assessment requirements. 1.5 Authorization and rules of engagement are confirmed following organizational procedures.
2. Perform static application security testing (SAST)	2.1 <u>SAST tools</u> are configured according to the target application and language. 2.2 Source code is scanned to identify vulnerabilities according to standard procedures. 2.3 Scan results are reviewed to confirm identified vulnerabilities. 2.4 False positives are identified and filtered according to standard practice. 2.5 SAST findings are documented following organizational procedures.
3. Perform dynamic application security testing (DAST)	3.1 <u>DAST tools</u> are configured according to the target application. 3.2 The running application is scanned to identify vulnerabilities according to standard procedures. 3.3 Basic <u>penetration testing techniques</u> are performed within the authorized scope. 3.4 Identified vulnerabilities are validated to confirm exploitability. 3.5 DAST and penetration testing findings are documented following organizational procedures.
4. Analyze vulnerability	4.1 Scan results from different tools are consolidated

findings	according to standard procedures. 4.2 Vulnerabilities are analyzed to determine their validity and impact. 4.3 Vulnerabilities are rated using <u>severity rating systems</u>. 4.4 Vulnerabilities are prioritized according to risk and business impact. 4.5 Prioritized findings are documented following organizational procedures.
5. Verify security controls	5.1 <u>Remediation measures</u> are verified against reported vulnerabilities according to standard procedures. 5.2 Security controls are tested to confirm correct implementation. 5.3 Remediated items are re-tested to confirm the vulnerabilities are resolved. 5.4 Residual risks are identified and recorded according to standard procedures. 5.5 Re-testing results are documented following organizational procedures.
6. Prepare vulnerability assessment reports	6.1 A vulnerability assessment <u>report</u> is prepared according to the reporting template. 6.2 Findings, severity ratings and remediation recommendations are presented clearly and accurately. 6.3 An executive summary is prepared for management according to organizational requirements. 6.4 The report is communicated to relevant <u>stakeholders</u> following organizational procedures. 6.5 Reports are stored securely according to organizational data protection requirements.

Range of Variables

Variable	Range (May includes but not limited to):
1. Scope and objectives	1.1 Target applications and systems 1.2 In-scope and out-of-scope assets 1.3 Assessment type (black-box, grey-box, white-box) 1.4 Testing timeframe 1.5 Compliance objectives 1.6 Success criteria 1.7 Constraints and limitations
2. Tools	2.1 SAST tools 2.2 DAST tools 2.3 Vulnerability scanners 2.4 Network scanners 2.5 Web proxies 2.6 Fuzzing tools 2.7 Dependency scanners

	2.8	Reporting tools
3. SAST tools	3.1	SonarQube
	3.2	Semgrep
	3.3	Fortify static code analyzer (SCA)
	3.4	Checkmarx
	3.5	Bandit
	3.6	ESLint security plugins
	3.7	CodeQL Language-specific linters
4. DAST tools	4.1	OWASP ZAP
	4.2	Burp Suite
	4.3	Nikto
	4.4	Nessus
	4.5	Acunetix
	4.6	Web vulnerability scanners
	4.7	API testing tools
5. Penetration testing techniques	5.1	Reconnaissance and information gathering
	5.2	Vulnerability identification
	5.3	Manual exploitation within scope
	5.4	Authentication testing
	5.5	Session management testing
	5.6	Input validation testing
	5.7	Privilege escalation testing Reporting
6. Severity rating systems	6.1	Common Vulnerability Scoring System (CVSS)
	6.2	CVSS Base
	6.3	CVSS environmental metrics
	6.4	Severity levels (critical, high, medium, low, informational)
	6.5	Common Vulnerabilities and Exposures (CVE)
	6.6	Common Weakness Enumeration (CWE)
	6.7	Risk-based prioritization
7. Remediation measures	7.1	Code fixes and patches
	7.2	Configuration changes
	7.3	Security control implementation
	7.4	Compensating controls
	7.5	Input validation and output encoding
	7.6	Access control corrections
	7.7	Dependency updates
8. Report	8.1	Executive summary
	8.2	Scope and methodology
	8.3	Findings and evidence
	8.4	Severity ratings
	8.5	Risk analysis Remediation recommendations
	8.6	Re-testing results
	8.7	Appendices
9. Stakeholders	9.1	Development team

	9.2 System administrators
	9.3 Project managers
	9.4 Security team
	9.5 Management
	9.6 Compliance officers
	9.7 Clients (as applicable)

Curricular Content Guide

1. Underpinning Knowledge	1.1 Concepts of vulnerability assessment and security testing. 1.2 Understand assessment scope, objectives, and rules of engagement. 1.3 Identify SAST, DAST, and penetration testing tools. 1.4 Understand static and dynamic application security testing procedures. 1.5 Understand basic penetration testing techniques. 1.6 Understand severity rating systems such as CVSS. 1.7 Understand remediation verification and re-testing procedures. 1.8 Understand vulnerability assessment reporting and communication. 1.9 Identify standard methodology and workplace requirements.
2. Underpinning Skills	2.1 Preparing a vulnerability assessment plan and test environment. 2.2 Configuring and using SAST tools to scan source code. 2.3 Configuring and using DAST tools and performing basic penetration testing. 2.4 Consolidating, analysing, and validating scan results. 2.5 Rating and prioritizing vulnerabilities using severity rating systems. 2.6 Verifying security controls and performing remediation re-testing. 2.7 Preparing and communicating vulnerability assessment reports. Documenting findings and storing reports securely.
3. Underpinning Attitudes	3.1 Commitment to occupational health and safety 3.2 Promptness in carrying out activities 3.3 Sincere and honest to duties 3.4 Environmental concerns 3.5 Eagerness to learn 3.6 Tidiness and timeliness 3.7 Respect for rights of peers and seniors in the workplace 3.8 Communication with peers, subordinates and seniors in the workplace
4. Resource Implications	The following resources must be provided:

	4.1 Workplace (simulated or actual) 4.2 Relevant tools, equipment and facilities needed to perform the activities. 4.3 Relevant materials for the proposed activity. 4.4 Learning materials
--	--

Assessment Evidence Guide

1. Critical Aspects of Competency	Assessment required evidence that the candidate: 1.1 prepared testing environment 1.2 performed static application security testing (SAST) 1.3 performed dynamic application security testing (DAST) 1.4 analyzed vulnerability findings 1.5 verified security controls 1.6 prepared vulnerability assessment reports
2. Methods of Assessment	Competency should be assessed by: 2.1 Written test 2.2 Practical Demonstration 2.3 Oral Questioning 2.4 Portfolio (Optional)
3. Context of Assessment	3.1 Competency assessment must be done in an assessment/training center or in an actual or simulated work place after completion of the training. 3.2 Assessment should be done by a nationally certified assessor or occupation-specific industry expert.

Unit of Competency: DEVELOP A SECURE SOFTWARE PROJECT (CAPSTONE)	Nominal Duration: 25 Hrs.	Unit Code: SICIP-ICT-CS-05-O
Unit Descriptor: This unit covers the knowledge, skills and attitudes required to develop a secure software project (capstone). It specifically includes the tasks of planning the project requirements, designing the secure application, developing the application, performing security testing and remediate, preparing project documentation and presenting project outcomes.		

Elements and Performance Criteria:

(Terms in the performance criteria that are written in **bold and underlined** are elaborated in the range of variables).

Elements of Competency	Performance Criteria
1. Plan the project requirements	1.1 The project <u>scope and objectives</u> are defined according to project requirements. 1.2 <u>Security requirements</u> are identified and documented according to standard practice. 1.3 Applicable <u>security standards</u> and compliance requirements are identified. 1.4 A project plan and schedule are prepared according to project requirements. 1.5 Resources and tools are identified and arranged according to the project plan.
2. Design the secure application	2.1 The application architecture is designed following <u>secure design principles</u> . 2.2 <u>Threat modeling</u> is performed to identify and address potential threats. 2.3 Security controls are incorporated into the design according to identified risks. 2.4 Data flow and trust boundaries are documented according to standard practice. 2.5 The secure design is reviewed and validated according to project requirements.
3. Develop the application	3.1 The application is developed applying <u>secure coding practices</u> . 3.2 Input validation, output encoding, authentication and authorization are implemented according to secure coding standards. 3.3 Cryptographic techniques are applied to protect sensitive data according to design requirements. 3.4 Secure error handling and logging are implemented

	according to secure coding standards. 3.5 Source code is managed using version control following organizational procedures.
4. Perform security testing and remediate	4.1 <u>Security testing</u> is performed on the developed application according to standard procedures. 4.2 Identified vulnerabilities are analyzed and prioritized according to severity. 4.3 Vulnerabilities are remediated applying appropriate <u>remediation measures</u>. 4.4 Remediated items are re-tested to confirm the vulnerabilities are resolved. 4.5 Testing and remediation activities are documented following organizational procedures.
5. Prepare project documentation	5.1 Project <u>documentation</u> is prepared according to the reporting template. 5.2 Design, test and remediation reports are compiled accurately and completely. 5.3 Documentation is reviewed for accuracy and completeness according to project requirements. 5.4 Documentation is version-controlled and stored securely following organizational procedures.
6. Present project outcomes	6.1 A <u>presentation</u> of the project outcomes is prepared according to requirements. 6.2 The security approach, findings and results are presented clearly and accurately. 6.3 Questions from the assessor or panel are answered accurately and confidently. 6.4 Design and implementation decisions are justified according to security principles. 6.5 Feedback is received and responded to professionally.

Range of Variables

Variable	Range (May includes but not limited to):
1. Scope and objectives	1.1 Project deliverables 1.2 Functional requirements 1.3 Non-functional requirements 1.4 Target users and platforms 1.5 Constraints and assumptions 1.6 Timeline and milestones 1.7 Success criteria
2. Security requirements	2.1 Authentication and authorization requirements 2.2 Data protection and encryption requirements Input validation requirements

	2.3 Logging and monitoring requirements 2.4 Access control requirements 2.5 Compliance requirements 2.6 Abuse and misuse cases
3. Security standards	3.1 OWASP Application Security Verification Standard (OWASP ASVS) 3.2 OWASP Top 10 3.3 ISO/IEC 27001 3.4 NIST Secure Software Development Framework (SSDF) 3.5 CIS Benchmarks 3.6 Payment Card Industry Data Security Standard (PCI DSS) 3.7 Data Protection Regulations (e.g., GDPR, CCPA, PDPA)
4. Secure design principles	4.1 Least Privilege 4.2 Defense in Depth 4.3 Fail-Secure Defaults 4.4 Separation of Duties 4.5 Minimize Attack Surface 4.6 Secure Defaults 4.7 Complete Mediation 4.8 Economy of Mechanism 4.9 Zero Trust
5. Threat modeling	5.1 STRIDE Methodology 5.2 Data Flow Diagrams (DFDs) 5.3 Asset and Entry Point Identification 5.4 Trust Boundary Analysis 5.5 Attack Surface Analysis 5.6 Mitigation Mapping 5.7 Risk Rating
6. Secure coding practices	6.1 Input Validation and Output Encoding 6.2 Parameterized Queries 6.3 Secure Authentication and Session Management 6.4 Least Privilege Authorization 6.5 Cryptographic Protection of Data 6.6 Secure Error Handling and Logging 6.7 Secure Dependency Management 6.8 Code Review
7. Security testing	7.1 Static application security testing (SAST) 7.2 Dynamic application security testing (DAST) 7.3 Dependency and composition analysis 7.4 Manual code review 7.5 Basic penetration testing 7.6 Security regression testing
8. Remediation measures	8.1 Code fixes

	8.2 Configuration changes 8.3 Dependency updates 8.4 Security control implementation 8.5 Compensating controls 8.6 Design changes 8.7 Re-testing
9. Documentation	9.1 Project plan 9.2 Security requirements document 9.3 Secure design document 9.4 Threat model 9.5 Test plan and results 9.6 Remediation report 9.7 User and deployment documentation
10. Presentation	10.1 Presentation slides 10.2 Live or recorded demonstration 10.3 Project report 10.4 Question-and-answer session 10.5 Technical walkthrough 10.6 Supporting evidence

Curricular Content Guide

1. Underpinning Knowledge	1.1 Concepts of secure software project development. 1.2 Understand project planning and security requirement definition. 1.3 Identify applicable security standards and compliance requirements. 1.4 Understand secure design principles and threat modeling. 1.5 Understand secure coding practices for application development. 1.6 Understand security testing and vulnerability remediation. 1.7 Understand project documentation and reporting requirements. 1.8 Understand presentation and defense of project outcomes. 1.9 Identify project specifications and workplace requirements.
2. Underpinning Skills	2.1 Planning a secure software project with defined security requirements. 2.2 Designing an application using secure design principles and threat modeling. 2.3 Developing an application applying secure coding practices. 2.4 Performing security testing and remediating identified

	vulnerabilities. 2.5 Preparing project documentation including design, test, and remediation reports. 2.6 Presenting and defending project outcomes. 2.7 Justifying design and implementation decisions according to security principles. 2.8 Managing source code and documentation using version control.
3. Underpinning Attitudes	3.1 Commitment to occupational health and safety 3.2 Promptness in carrying out activities 3.3 Sincere and honest to duties 3.4 Environmental concerns 3.5 Eagerness to learn 3.6 Tidiness and timeliness 3.7 Respect for rights of peers and seniors in the workplace 3.8 Communication with peers, subordinates and seniors in the workplace
4. Resource Implications	The following resources must be provided: 4.1 Workplace (simulated or actual) 4.2 Relevant tools, equipment and facilities needed to perform the activities. 4.3 Relevant materials for the proposed activity. 4.4 Learning materials

Assessment Evidence Guide

1. Critical Aspects of Competency	Assessment required evidence that the candidate: 1.1 planned the project requirements 1.2 designed the secure application 1.3 developed the application 1.4 performed security testing and remediate 1.5 prepared project documentation 1.6 presented project outcomes
2. Methods of Assessment	Competency should be assessed by: 2.1 Written test 2.2 Practical Demonstration 2.3 Oral Questioning 2.4 Portfolio (Optional)
3. Context of Assessment	3.1 Competency assessment must be done in an assessment/training center or in an actual or simulated work place after completion of the training. 3.2 Assessment should be done by a nationally certified

	assessor or occupation-specific industry expert.
--	--

End of the Unit of Competency

Workshop/Lab Facility Standard

Course Name:	Cyber Security (Advanced)
Number of Trainees:	30

Course-wise Training Space (Theoretical Classroom, Workshop/ Lab/ Classroom cum Workshop):

- Classroom cum workshop – 500 - 600 sft (50-55 sqm)

Major Training Equipment and Training Facilities:

Sl. No.	Major Equipment and Training facilities	Required facilities
1	Laptop/ Desktop (i5 or higher, 16 GB RAM, SSD)	30
2	Server / Workstation for lab (multi-core, 32 GB RAM)	2
3	Power Backup / UPS (at least 01 hour)	2
4	Printer	1
5	Scanner	1
6	Projector or Large Display Screen	1
7	White board	1
8	Managed Network Switch (24-port, Gigabit)	2
9	Router with firewall capability	2
10	Wireless Access Point	2
11	Internet Connection (dedicated bandwidth)	1
12	Network Attached Storage (NAS) for backups	1
13	Hypervisor / Virtualization platform licenses (e.g., VMware/Hyper-V)	As Required
14	Integrated Development Environment (IDE) software	30
15	Version Control System (Git) with repository server	1
16	SAST tool licenses (e.g., SonarQube/Semgrep)	As Required
17	DAST / Web proxy tools (e.g., OWASP ZAP, Burp Suite)	30
18	Vulnerability scanner licenses (e.g., Nessus/OpenVAS)	As Required
19	Dependency / SCA scanning tools	As Required
20	Isolated cyber lab / sandbox network (air-gapped segment)	1

Sl. No.	Major Equipment and Training facilities	Required facilities
21	Database server software (secured lab instance)	2
22	Web/Application server software (secured lab instance)	2
23	SIEM / Log management tool (lab edition)	1
24	Web Application Firewall (WAF) (lab/test edition)	1
25	Antivirus / Endpoint protection software	30
26	Password manager / secrets management tool	As Required
27	Multi-factor authentication (MFA) tokens/app	As Required
28	Whiteboard markers, tools, and consumables	As Required

The following conditions must be fulfilled –

- The institute shall not use the same facilities for any other projects/organizations offering a similar course.
- The institute must provide sufficient evidence to prove ownership of the proposed training equipment.

The list denotes the minimum training equipment and facility required to effectively conduct training for a specific course. Additionally, the institute must ensure that all other necessary training tools, equipment, and furniture are available to meet the requirement of competency standards (CS) provided by SICIP.

For the operation of training course on Cyber Security (Advanced), the institute must ensure the availability of at least 80% of the major training equipment and training facilities (according to the CS) to be eligible for SICIP training delivery. If the score is below 80%, the remaining equipment and facilities need to be installed before the commencement of the training.

The institute will also provide all other hand tools and power tools as per CS for 30 trainees. Also, they will arrange adequate seating arrangement and classroom setup for the 30 trainees.
